SECURITY AUDIT REPORT

Milestone 1
Gaps & Findings Report

CONFIDENTIAL

Riayah Plus Platform

PERN-Stack Care Platform Security Assessment

PREPARED BY

KARIM ASHRAF

Security Auditor & Reviewer

Report Date:	10 July 2026
Branch:	milestone-1 (commit aab24f6)
Status:	Partial — requires action before M2 start
Total Gaps:	35 across 6 audit areas

Executive Summary

This report consolidates all verified gaps and issues found during the Milestone 1 security audit of the Riayah Plus platform — a PERN-stack care management system built with Node.js, Express, PostgreSQL (Prisma), and Vite/React. The audit covers six functional areas: Authentication, RBAC, Organization Hierarchy, UI Shells, Audit Logging, and Backend Stubs. Each gap was directly verified against the actual codebase on the **milestone-1** branch (commit **aab24f6**).

31	3	15	13	23
Total Gaps	HIGH	MEDIUM	LOW	Verified Working

Audit Areas Covered

#	Area	Gaps	Scope
1	Auth Area	3 gaps	Login, registration, 2FA, OTP, sessions, tokens
2	RBAC Area	3 gaps	Route protection, role guards, granular permissions, tenant scoping
3	Org Hierarchy	7 gaps	Organization → Clinic → Department management
4	UI Shells	4 gaps	6 role-based portal shells, login pages, navigation
5	Audit Logging	7 gaps	Auto-logging middleware, admin audit logs page
6	Backend Stubs	7 gaps	Permissions matrix, tenant scoping, state machines, security

Re-Verification Process

All 41 original gaps were re-verified against the actual codebase by reading each referenced source file. 8 false positives were removed (AUTH-006, AUTH-007, RBAC-001, ORG-003, SHELL-001, SHELL-004, SHELL-005, AUDIT-004). AUTH-001 was narrowed from "all login pages" to "admin and provider login pages only" (careseeker already has full 2FA support). 2 missing security gaps were discovered and added: STUB-006 (requireAdmin header backdoor) and STUB-007 (authenticate middleware does not check isActive/deletedAt). 4 gaps were removed by client request (AUTH-003, AUTH-004, AUTH-008, AUTH-009). Final total: **31 verified gaps**.

Severity Legend

CRITICAL	Security, data loss, or legal compliance risk	**Fix immediately — do not deploy without**
HIGH	Feature broken or incomplete; blocks user journey	**Fix before M1 sign-off**
MEDIUM	Partial implementation; workaround exists	**Fix before M2 start**
LOW	Cosmetic, performance, or nice-to-have	**Fix when convenient**

Section 1 — Auth Area

3 gaps: 2 HIGH, 1 MEDIUM

HIGH

ID	Issue	Detail	File(s)	Recommended Fix
AUTH-001	**2FA login UI missing on Admin and Provider login pages**	Backend returns `requires2fa: true` and `AuthContext.tsx` has `complete2faLogin()` + `TwoFactorRequiredError` handling. The careseeker LoginPage fully supports 2FA. However, **Admin** and **Provider** login pages do NOT catch `TwoFactorRequiredError` — 2FA-enabled users on those portals cannot log in.	`client/src/pages/admin/LoginPage.tsx`, `client/src/pages/provider/LoginPage.tsx`	Add `isTwoFactorRequiredError` catch + 2FA code step to admin and provider login forms
AUTH-002	**Phone OTP returns** `503`	`POST /otp/send` with `type: 'phone'` returns honest `503` — no SMS/WhatsApp gateway wired.	`server/src/controllers/auth/OtpController.ts`	Integrate WhatsApp Business API or SMS provider

MEDIUM

ID	Issue	Detail	File(s)	Recommended Fix
AUTH-005	**Session list returns** `RefreshToken` **rows, not** `UserSession` **rows**	`UserSession` model exists but is never populated. Sessions display refresh tokens instead.	`server/src/controllers/auth/AuthController.ts:328`	Populate `UserSession` on login or remove model

Section 2 — RBAC Area

3 gaps: 2 MEDIUM, 1 LOW

MEDIUM

ID	Issue	Detail	File(s)	Recommended Fix
RBAC-002	**Granular permissions only wired on org routes**	Most `/admin/*` routes (users, bookings, payments, payouts, documents, audit logs, settings, reports) use `requireAdmin` only — they do NOT use `requireView('user')`, `requireEdit('user')`, etc.	`server/src/routes/admin.routes.ts`	Apply `requireView`/`requireEdit`/`requireDelete` to all admin routes
RBAC-003	`tenantScope` **not mounted globally**	`tenantScope.ts` defines `attachTenantContext` but is not imported or used in `app.ts` or any route file. Multi-tenant filtering is inactive.	`server/src/middleware/tenantScope.ts`, `server/src/app.ts`	Import and mount `attachTenantContext` after `authenticate`

LOW

ID	Issue	Detail	File(s)	Recommended Fix
RBAC-004	**Proposal role shell stats are placeholders**	Dashboards show "—" stats by design (M1 shell deliverable) — but this is expected and documented.	`client/src/config/proposalRoleShells.ts`	Wire to APIs in M2

Section 3 — Org Hierarchy Area

7 gaps: 4 MEDIUM, 3 LOW

MEDIUM

ID	Issue	Detail	File(s)	Recommended Fix
ORG-001	**Clinic and Department** `name` **fields have no uniqueness constraints**	Schema does not enforce unique names per parent. Two clinics in the same org or two departments in the same clinic can have identical names, breaking dropdown/select reliability.	`server/prisma/schema.prisma:221` (Clinic), `:238` (Department)	Add `@@unique([organizationId, name])` on Clinic; `@@unique([clinicId, name])` on Department
ORG-002	**No DB indexes on hierarchy FKs**	`clinic.organizationId`, `department.clinicId`, and `user.organizationId/clinicId/departmentId` have no indexes. Admin org list and user lookups will scan at scale.	`server/prisma/schema.prisma:221-250`	Add `@@index` on all hierarchy FKs
ORG-004	**Clinic edit modal reuses** `email`/`website` **fields from org form**	`openClinicEdit()` sets `email: ''` and `website: ''` but Clinic model has no `email` or `website` fields. The modal displays orphaned inputs that are sent to the API but silently dropped.	`client/src/pages/admin/OrganizationsPage.tsx:145-153`	Remove `email` and `website` from clinic edit modal; align to Clinic schema
ORG-005	**Organization logo upload UI exists in schema but not in UI**	`Organization.logoUrl` field exists and is persisted on create/update, but the admin UI has no logo upload or preview.	`client/src/pages/admin/OrganizationsPage.tsx`	Add logo upload input or image URL field in create/edit modal

LOW

ID	Issue	Detail	File(s)	Recommended Fix
ORG-006	**Delete cascade missing**	Prisma relations do not define `onDelete: Cascade`. Deleting an org or clinic orphaned in DB if FK constraints allow it, or fails with FK violation if they don't.	`server/prisma/schema.prisma:215` (clinics), `:232` (departments)	Add `onDelete: Cascade` or handle in controller with explicit child cleanup
ORG-007	**No search/filter on clinics or departments**	`listClinics` and `listDepartments` return all rows with no query filtering. At scale this returns too much data.	`server/src/controllers/admin/OrganizationController.ts:215, :345`	Add `search` and `active` query param filters
ORG-008	**Seed data is hard-coded to specific IDs**	`seed.ts` uses literal IDs for org/clinic/dept creation. This is fragile and breaks if seed is run in different order.	`server/prisma/seed.ts:54-133`	Use `upsert` with unique lookup keys instead of hard-coded IDs

Section 4 — UI Shells Area

4 gaps: 2 MEDIUM, 2 LOW

MEDIUM

ID	Issue	Detail	File(s)	Recommended Fix
SHELL-002	**Proposal role shell placeholders have no real data**	All 5 proposal shells (`/family`, `/patient`, `/coordinator`, `/clinical`, `/support`) render static "—" stats and placeholder text. They do not fetch any API data.	`client/src/pages/roles/RoleShellDashboard.tsx`	Wire dashboard stats to backend APIs (M2 scope)
SHELL-003	**No dedicated login pages for proposal roles**	ProposalPortalLoginPage does show `shell.portalTitle` and `shell.roleBadge` branding, but has no role-specific auth flow or 2FA handling.	`client/src/routes/getLoginRedirectForPath.ts:22-26`	Create dedicated login pages per portal or enhance ProposalPortalLoginPage with 2FA support

LOW

ID	Issue	Detail	File(s)	Recommended Fix
SHELL-006	**Admin layout badge count is static**	`NAVIGATION` items define `badge?: number` but no live counts are fetched (e.g., pending verifications, unread disputes).	`client/src/layouts/AdminLayout.tsx:23-68`	Add API polling or WebSocket for live badge counts
SHELL-007	**Role shells do not handle mobile deep linking**	No `window.location` fallback or PWA manifest entries for role-specific paths.	`client/src/routes/ProposalRoleRoutes.tsx`	Add route-based meta tags and PWA scope per shell

Section 5 — Audit Logging Area

7 gaps: 1 HIGH, 3 MEDIUM, 3 LOW

HIGH

ID	Issue	Detail	File(s)	Recommended Fix
AUDIT-001	**Frontend AuditLog interface doesn't match backend schema**	`AuditLogsPage.tsx` expects fields: `id`, `action`, `user`, `role`, `timestamp`, `ipAddress`, `status`, `details` — but backend `AuditLog` model stores: `id`, `userId`, `action`, `entity`, `entityId`, `ipAddress`, `userAgent`, `deviceInfo`, `before`, `after`, `metadata`, `createdAt`. Table renders blank cells for most data.	`client/src/pages/admin/AuditLogsPage.tsx:8-17`	Fix frontend interface to match backend fields: show `userId`, `entity`, `action`, `createdAt`, `ipAddress`, `metadata.statusCode`

MEDIUM

ID	Issue	Detail	File(s)	Recommended Fix
AUDIT-002	**No `userId` filter on admin `/audit-logs` endpoint**	`AuditService.getAll()` accepts `userId` but `admin.routes.ts` only passes `entity` and `action`. Cannot filter by specific user.	`server/src/routes/admin.routes.ts:115-118`	Add `userId` query param support

ID	Issue	Detail	File(s)	Recommended Fix
AUDIT-003	**No date range filter on audit logs**	Common audit need is "show logs from last 7 days" or "between X and Y". Not supported in `getAll()`.	`server/src/services/AuditService.ts:87-108`	Add `from`/`to` date filters to `getAll()` and expose in API
AUDIT-005	**Audit log table lacks pagination controls**	`AuditLogsPage` shows all logs but `AuditService.getAll()` paginates. No page/next/previous UI.	`client/src/pages/admin/AuditLogsPage.tsx`	Add pagination controls (page numbers, limit selector, total count display)

LOW

ID	Issue	Detail	File(s)	Recommended Fix
AUDIT-006	**No export functionality on Export Logs button**	"Export Logs" button is present but has no `onClick` handler. No CSV/Excel export API exists.	`client/src/pages/admin/AuditLogsPage.tsx:81-84`	Add CSV export endpoint + frontend handler, or hide button until implemented
AUDIT-007	`deviceInfo` **not displayed in audit log UI**	Backend captures browser/OS/device type but frontend doesn't show it.	`client/src/pages/admin/AuditLogsPage.tsx`	Add device info column or tooltip
AUDIT-008	**No** `@@index([createdAt])` **on AuditLog**	Frequently queried by date range for compliance reports, but no index on `createdAt`.	`server/prisma/schema.prisma:1485-1503`	Add `@@index([createdAt])`

Section 6 — Backend Stubs Area

7 gaps: 3 MEDIUM, 4 LOW (includes 2 security findings)

MEDIUM

ID	Issue	Detail	File(s)	Recommended Fix
STUB-001	`tenantWhere()` **and** `requireTenantOrganization()` **defined but never used**	`tenantScope.ts` exports `tenantWhere()` and `requireTenantOrganization()` but **zero controllers import them**. Multi-tenant query scoping is completely unimplemented — every controller returns all-org data.	`server/src/middleware/tenantScope.ts:66-100`	Import `tenantWhere` in list/get controllers and merge into Prisma `where` clauses
STUB-002	**State machine not enforced on Booking status changes**	`BookingExtrasController.ts:159` updates `status: 'cancelled'` directly without calling `assertAppointmentTransition()`. Invalid transitions (e.g. `completed` → `pending`) are possible.	`server/src/controllers/booking/BookingExtrasController.ts`	Add `assertAppointmentTransition()` before every status update
STUB-003	**Permission matrix missing legacy provider roles**	`permissions.ts` `ROLE_PERMISSIONS` only defines matrices for 6 proposal roles. Legacy marketplace roles (`provider`, `doctor`, `nurse`, etc.) are absent and fall through to `return false`.	`server/src/middleware/permissions.ts:37-79`	Add provider role matrices or map them to clinical_staff/support_worker equivalents

LOW

ID	Issue	Detail	File(s)	Recommended Fix
STUB-004	**State machine only covers 3 entity types**	`stateMachine.ts` guards `care_episode`, `care_plan`, `appointment`. Many Prisma models with status fields (Document, Invoice, PayoutRequest, etc.) have no transition validation.	`server/src/utils/stateMachine.ts:12-50`	Expand `StateMachineEntity` union and add transition matrices for Document, Invoice, PayoutRequest, etc.
STUB-005	**No runtime enum validation on** `req.user.role`	`rbac.ts` and `permissions.ts` accept `req.user.role` as a `UserRole` enum but never validate at runtime that the string is a valid enum member. Invalid roles silently fail permission checks.	`server/src/middleware/rbac.ts:59-74`, `permissions.ts:99-112`	Add `Object.values(UserRole).includes(role)` guard early in middleware chain
STUB-006	`requireAdmin` **backdoor via** `x-admin-request` **header**	`requireAdmin` accepts `req.headers['x-admin-request'] === env.ADMIN_SECRET` as an alternative to having an admin role. Any authenticated user can bypass admin checks if they know the `ADMIN_SECRET`. If the secret leaks, the entire admin API is compromised.	`server/src/middleware/rbac.ts:66-67`	Remove the header backdoor, or restrict it to internal service-to-service calls only
STUB-007	`authenticate` **middleware doesn't check** `isActive` **or** `deletedAt`	`authenticate` only verifies the JWT signature — it does NOT check if the user is still active or deleted. A suspended user (`isActive: false`) retains full API access until their JWT expires (15 minutes). An admin suspending a user does not immediately revoke their access.	`server/src/middleware/auth.ts:24-38`	Add a DB check (with short-lived cache) for `isActive` and `deletedAt` in `authenticate`, or use a token revocation list

Section 7 — M1 Sign-off Blockers

These are the P0 items from the M1 deliverables checklist that must be completed before the client can sign off:

#	Deliverable	Status	Blocker
1	Auth system (web)	~95%	2FA UI missing on admin/provider login (AUTH-001); phone OTP gateway (AUTH-002)
2	PostgreSQL + schema + migrations	~80%	Migrations not committed to git; no `db:deploy` script
3	RBAC middleware	~85%	Granular permissions only on org routes (RBAC-002); tenant not mounted (RBAC-003)
4	Org hierarchy (Admin)	~95%	—
5	Adaptive UI shell (6 roles)	~90%	—
6	Audit logging foundation	~90%	—
7	**Staging deploy (EC2 + Vercel)**	**0%**	**Not started — blocks formal sign-off**

P0 — Must Complete Before Client Sign-off

• **1. Staging deploy** — API on EC2, client on Vercel

• **2. Prisma migrations in git** + `prisma migrate deploy` on staging RDS

• **3. Staging env vars documented** + smoke test (GET /api/health, login, CORS/cookies Vercel→EC2)

Section 8 — Quick Reference: Verified vs Missing

Verified Working (Do Not Re-audit)

Feature	Evidence
Register with email verification enforced	`RegistrationController.ts:64`
Login blocked for unverified email	`AuthController.ts:84-86` → 403 if !isEmailVerified
Email verification link handler	`AuthController.ts:431` → GET /email/verify
Public resend verification	`AuthController.ts:402` → POST /email/resend-verification
Refresh token hashing (HMAC-SHA256)	`refreshTokenHash.ts:5` + `refreshTokenStore.ts:8`
Legacy plaintext token fallback	`refreshTokenStore.ts:30`
Device token API (CRUD)	`DeviceTokenController.ts` + 4 endpoints
Password reset (token + 1h expiry)	`AuthController.ts:232-256`
Session list + revoke + revoke-others	`AuthController.ts:328`
Role-based route guards (client)	`RoleRoute.tsx` + `getRoleDashboard.ts`
6 proposal role shells	/family, /patient, /coordinator, /clinical, /support
Admin-only org API	`OrganizationController.ts` + granular requirePermission
Full org hierarchy CRUD (org + clinic + dept)	15 endpoints wired with granular RBAC
Org hierarchy admin UI	`OrganizationsPage.tsx` with tree view, modals, CRUD
Audit middleware (auto logging)	`auditMiddleware.ts` mounted in `routes/index.ts:51`
Rate limiting on auth endpoints	loginLimiter, otpLimiter, registerLimiter, adminLimiter
2FA login UI (careseeker)	`careseeker/LoginPage.tsx` — full 2FA step + complete2faLogin()
AuthContext.mapUserData() splits name → firstName	`AuthContext.tsx:80-86` — layouts work correctly
support_admin in client ADMIN_ROLES	`getRoleDashboard.ts:10` — includes support_admin
isActive toggle in org/clinic/dept update	`OrganizationController.ts` — Zod + controller spread
Seed isEmailVerified persists on re-seed	`seed.ts` — all upsert update blocks include it
Audit dedup flag prevents duplicate entries	`AuditService.ts:27` + `auditMiddleware.ts:55`
Logout + logout-all	`AuthController.ts` — revokes tokens + clears cookies

Not Yet Implemented / Requires Fix

Feature	Gap	Owner
2FA login UI (admin + provider)	Admin and provider login pages don't catch TwoFactorRequiredError	Frontend
Phone OTP delivery	Returns 503; no gateway	Backend / DevOps
Staging deploy	Not started	DevOps
Prisma migrations in git	Not committed	Backend
Granular RBAC on all admin routes	Only org routes use requirePermission	Backend
Tenant scoping globally	tenantScope.ts not mounted	Backend
Clinic/dept name uniqueness	No DB constraints	Backend
Hierarchy FK indexes	Missing @@index on FKs	Backend

Feature	Gap	Owner
Proposal shell login pages	Generic login, no 2FA handling	Frontend
Audit log frontend interface	Mismatched fields cause blank table cells	Frontend
Multi-tenant query scoping	tenantWhere() never imported by controllers	Backend
Booking state machine not enforced	Status updates bypass assertAppointmentTransition()	Backend
requireAdmin header backdoor	x-admin-request header bypasses role check	Backend
authenticate doesn't check isActive	Suspended users retain access until JWT expiry	Backend

Section 9 — Suggested Fix Order

Week 1 (M1 Closure)

1. Commit prisma/migrations/ to git + add db:deploy script

2. Staging deploy (EC2 API + Vercel client)

3. Smoke test (health, login, org admin, role shells, CORS/cookies)

4. Add 2FA handling to admin + provider login pages (AUTH-001) — backend ready, careseeker already works

Week 2 (M1 Polish / M2 Prep)

5. Extend granular RBAC to all admin routes (RBAC-002)

6. Mount tenantScope globally (RBAC-003)

7. Add DB uniqueness/index constraints for org hierarchy (ORG-001, ORG-002)

8. Fix clinic edit modal orphaned fields (ORG-004)

9. Add logo upload to org UI (ORG-005)

10. Fix audit log frontend interface mismatch (AUDIT-001) — quick UI fix

11. Add userId and date range filters to audit logs (AUDIT-002, AUDIT-003)

12. Wire tenantWhere() into list controllers for multi-tenant scoping (STUB-001)

13. Add assertAppointmentTransition() to Booking status updates (STUB-002)

14. Phone OTP gateway integration (AUTH-002)

15. Remove or restrict requireAdmin header backdoor (STUB-006)

16. Add isActive/deletedAt check in authenticate middleware (STUB-007)

Changelog

Date	Action	By
2026-07-10	Initial audit — Auth + RBAC areas	Karim Ashraf
2026-07-10	Org hierarchy audit added — 8 gaps found (ORG-001 to ORG-008)	Karim Ashraf
2026-07-10	UI Shells audit added — 7 gaps found (SHELL-001 to SHELL-007)	Karim Ashraf
2026-07-10	Audit Logging audit added — 8 gaps found (AUDIT-001 to AUDIT-008)	Karim Ashraf
2026-07-10	Backend Stubs audit added — 5 gaps found (STUB-001 to STUB-005)	Karim Ashraf
2026-07-10	Re-verification against codebase — 8 false positives removed, AUTH-001 narrowed, 2 missing security gaps added (STUB-006, STUB-007), 4 gaps removed by client request (AUTH-003, AUTH-004, AUTH-008, AUTH-009). Total: 31 verified gaps.	Karim Ashraf

End of report. Update this document as gaps are resolved. Mark items as [DONE] and add resolution date.

Prepared by Karim Ashraf — Security Auditor & Reviewer — 10 July 2026